
Normes et standards de la cybersécurité

Jour 3

Gouvernance des infrastructures Systèmes et Réseaux

DORA - Digital Operational Resilience Act (UE)

Assurer que les banques, assurances, fintech, prestataires cloud, etc., puissent résister aux cyberattaques, pannes, incidents et perturbations.

Domaines couverts

- Gestion des risques TIC (Technologies de l'Information et de la Communication)
- Gestion des incidents & reportings aux autorités
- Tests de résilience (TLPT : Threat-Led Penetration Testing)
- Gestion des fournisseurs critiques (cloud, SaaS...)
- Partage d'informations sur les cybermenaces

Objectifs :

- Uniformise les règles dans l'UE
- Renforce la sécurité des services financiers, très ciblés
- Implique les fournisseurs cloud (notamment hyperscalers)

Type d'entreprise couverte : Banques, assurances, fintech, Bourse, prestataires IT du monde financier.

Le règlement DORA est applicable depuis le 17 janvier 2025.

Obligations clés pour les entreprises

- Mettre en place une gouvernance robuste
- Réaliser une analyse de risques TIC
- Avoir un dispositif de gestion des incidents
- Produire un reporting d'incident dans les délais obligatoires
- Évaluer et contrôler tous les prestataires TIC
- Mettre en place un plan de continuité & PRA
- Tester régulièrement la résilience numérique
- Conserver une documentation exhaustive

Les entités financières doivent déclarer les incidents considérés comme majeurs à leur autorité sectorielle compétente.

HIPAA (USA) - Health Insurance Portability and Accountability Act

L'HIPAA est une loi américaine (1996) encadrant la protection et la confidentialité des informations médicales personnelles (PHI).

- Privacy Rule : droits des patients, consentement, divulgation minimale
- Security Rule : mesures techniques, physiques et organisationnelles
- Breach Notification Rule : obligation de notifier les incidents
- Enforcement Rule : sanctions en cas de non-conformité

Exigences techniques

- Contrôle d'accès
- Journalisation
- Audit des accès
- Chiffrement recommandé
- Plan de continuité et de reprise

HIPAA est l'équivalent américain de HDS/RGPD pour le domaine de la santé.

ITIL - Information Technology Infrastructure Library

Définition

ITIL est un cadre de bonnes pratiques IT qui structure la gestion des services informatiques.

La dernière version : ITIL 4.

Objectifs :

Assurer que les services IT sont fiables, contrôlés, mesurables, et alignés avec les besoins métiers.

Principaux processus ITIL

- Incident Management
- Problem Management
- Change Enablement (anciennement Change Management)
- Configuration Management
- Service Level Management
- Release Management

Pourquoi c'est important en cybersécurité ?

- Normalise la gestion des incidents
- Améliore la traçabilité du changement
- Réduit les risques opérationnels

IEC 62443 - Sécurité des systèmes industriels (OT)

Définition

Série de standards internationaux pour la cybersécurité des systèmes industriels (ICS) : usines, énergie, transport, traitement de l'eau, etc.

Les réseaux industriels étaient historiquement isolés : aujourd'hui connectés et davantage très exposés.

Organisée en 4 familles :

- 62443-1-x : Généralités
- 62443-2-x : Politiques & organisation
- 62443-3-x : Systèmes
- 62443-4-x : Composants

Principes clés

Défense en profondeur

Zones et conduits

Gestion des fournisseurs

Niveau de sécurité requis (SL1 à SL4)

CSA CCM - Cloud Controls Matrix (Cloud Security Alliance)

Définition

Référentiel mondial regroupant 197 contrôles de sécurité cloud, classés par domaine.

Utilisé pour évaluer la maturité d'un fournisseur cloud.

Domaines couverts :

- Gouvernance
- Sécurité des données
- Identity & Access Management
- Journalisation / Monitoring
- Virtualisation
- DevSecOps
- Infrastructure as Code
- Continuité d'activité
- Conformité réglementaire

Pourquoi c'est important ?

De plus en plus utilisé pour les audits cloud

Complémentaire à SecNumCloud

Support de la certification STAR de la CSA

COBIT 2019 - Gouvernance et management du SI

Définition

COBIT (Control Objectives for Information and related Technologies) est un cadre de gouvernance IT, publié par l'ISACA.

Objectif :

S'assurer que les systèmes d'information créent de la valeur, tout en maîtrisant les risques.

Domaines de Gouvernance (EDM)

- Évaluer
- Diriger
- Surveiller

Domaines de Management (APO, BAI, DSS, MEA)

- Planifier
- Concevoir
- Construire
- Opérer
- Superviser

CWE / CVE – Référentiels de vulnérabilités

CVE : Common Vulnerabilities and Exposures

Base mondiale recensant les vulnérabilités connues dans les logiciels et systèmes.

CWE : Common Weakness Enumeration

La CWE est un référentiel mondial qui répertorie et classe les faiblesses de sécurité logicielles susceptibles d'être exploitées par des attaquants.

CWE = la liste des types de failles que l'on peut créer en programmant mal.

Elle est maintenue par le MITRE, l'organisme américain qui gère aussi MITRE ATT&CK et CVE.

Introduction aux rapports SOC : SOC 1, SOC 2 et SOC 3

Qu'est-ce que la famille des rapports SOC ?

Les rapports SOC (System and Organization Controls) ont été créés par l'AICPA pour évaluer les contrôles internes des organisations qui fournissent des services à d'autres entreprises.

Ils permettent aux clients de vérifier la fiabilité, la sécurité et la conformité d'un prestataire.

- SOC 1 - Contrôles sur les états financiers
- SOC 2 - Contrôles sur la sécurité et la confiance
- SOC 3 - Version publique et simplifiée de SOC 2

Qu'est-ce que SOC 2 ?

SOC 2 (System and Organization Controls 2) est un référentiel américain développé par l'AICPA, destiné à évaluer :

la sécurité,
la confidentialité,
la disponibilité,
l'intégrité du traitement,
et la protection de la vie privée

des systèmes d'information des prestataires de service.

SOC 2 permet :

- d'attester des pratiques de sécurité d'un fournisseur ;
- de rassurer les clients et partenaires ;
- de répondre aux exigences contractuelles ;
- d'améliorer la maturité technique et organisationnelle ;
- d'éviter des audits multiples (standard reconnu internationalement).

Les 5 Trust Services Criteria (TSC) - Type I vs Type II

SOC 2 repose sur 5 critères de confiance :

- Sécurité (obligatoire)
- Disponibilité
- Intégrité du traitement
- Confidentialité
- Vie privée (Privacy)

SOC 2 Type I

- Évalue la conception des contrôles
- À un instant T

Question : Les contrôles sont-ils correctement définis aujourd'hui ?

SOC 2 Type II

- Évalue la mise en œuvre réelle
- Sur une période (3 à 12 mois)

Question : Les contrôles ont-ils réellement fonctionné dans le temps ?

Exemples de contrôles SOC 2

Sécurité

- MFA obligatoire
- Contrôle d'accès strict
- Chiffrement des données

Intégrité du traitement

- Traçabilité des traitements
- Détection d'erreurs et correction

Disponibilité

- Monitoring 24/7
- Plan de continuité et PRA

Confidentialité

- Classification des données
- Journalisation d'accès sensibles

Vie privée

- Consentement des utilisateurs
- Limitation de la collecte

Les 5 Trust Services Criteria (TSC) - Type I vs Type II

SOC 2 repose sur 5 critères de confiance :

- Sécurité (obligatoire)
- Disponibilité
- Intégrité du traitement
- Confidentialité
- Vie privée (Privacy)

SOC 2 Type I

- Évalue la conception des contrôles
- À un instant T

Question : Les contrôles sont-ils correctement définis aujourd'hui ?

SOC 2 Type II

- Évalue la mise en œuvre réelle
- Sur une période (3 à 12 mois)

Question : Les contrôles ont-ils réellement fonctionné dans le temps ?

Exercice : référentiels à présenter

- MITR ATTACK
- SecNumCloud
- PDIS
- PAMS
- PVID
- eIDAS
- OWASP Top 10
- OWASP ASVN
- CIS Benchmark
- SOC 2

Questions ? / Réponses

